

# Hobbeast — Üzleti kérés összefoglaló

Verzió: 1.59.0    Dátum: 2026-09-05

## RLS: a két védtelen tábla lezárva, a nézetek egyenként megmérve

Két tábla teljesen RLS nélkül állt — a Supabase advisor ERROR szinten jelezte őket. Mindkettő a hosztolt dashboardon készült, és a 20260824010000\_restore\_schema\_parity.sql pontosan úgy reprodukálta őket, ahogy az élesben voltak: kikapcsolt RLS-sel. event\_views (event\_id, user\_id, source, view\_count, last\_viewed\_at) — személyre szóló megtekintési előzmény. RLS nélkül **\*\*bármely bejelentkezett kliens olvashatta, ki mit nézett meg\*\***, és írhatott más nevére sort. Mostantól: csak a saját sorai, SELECT/INSERT/UPDATE user\_id = auth.uid() mellett, DELETE policy szándékosan nincs. organizer\_audit\_log — auditnapló. RLS nélkül bárki olvashatta az összes szervezői műveletet, és — ami rosszabb — bejegyzést is szűrhatott bele, ami az auditnapló egyetlen tulajdonságát semmisíti meg. Mostantól olvasás is\_event\_operator(event\_id, 'moderate') mellett, **\*\*írási policy pedig egyáltalán nincs\*\***: bejegyzés csak service\_role vagy SECURITY DEFINER függvény útján keletkezhet.

Mindkettő üres volt és a src/ sehol nem hivatkozik rájuk, tehát működő funkció nem sérülhetett. A szigetelést le is mértem két valódi felhasználóval szimulálva: A csak a saját sorát látja (1, nem 2), B ugyanígy, egy nem-operátor 0 auditsort lát, és B nem tud A nevére sort hamisítani — a próba utána kitakarított maga után. A public sémában így **\*\*nulla tábla maradt RLS nélkül\*\***.

A 16 „RLS bekapcsolva, nulla policy” táblát NEM nyitottam ki. Ezek rls\_enabled\_no\_policy figyelmeztetést kapnak, de a deny-all itt szándékos: egyikre sincs kliens-hivatkozás a src/-ben (lemérve, mind a 16-nál nulla), és kizárólag SECURITY DEFINER RPC-ken vagy service\_role-on át érhetők el, amelyek átmennek az RLS-en. Egy megengedő policy hozzáadása **\*\*kinyitna egy jelenleg zárt táblát\*\*** — ezért mindegyik kapott egy COMMENT-et, hogy a figyelmeztetést később se „javítsa meg” senki.

## A definer nézetek: 3 átállítva, 2 szándékosan nem

Nyolc nézet fut definer jogokkal, ötöt elér a kliens. Az „állítsuk át mind az ötöt” egysoros javítás lett volna — és kettő némán eltört volna tőle, ezért mindegyiket élesben megmértem, valódi nem-admin felhasználóként, a beállítást egy tranzakción belül átbillentve és visszaállítva:

Átállítva security\_invoker=true-ra: public\_event\_safety (eddig semmilyen WHERE-je nem volt, vagyis bárki olvashatta az összes esemény biztonsági profilját — az alaptábla policy-je „safety reviewer vagy az esemény létrehozója”, ez a helyes közönség), promoted\_experience\_candidates (a predikátuma megegyezik az alaptábla saját policy-jével), virtual\_hub\_discovery\_cards (a virtual\_hubs policy pont ezt a halmazt engedi).

Szándékosan definer marad — az advisor tovább fogja jelezni, és ez a helyes: public\_profile\_cards — 934 → 1. A nézet éppen azért létezik, hogy a zárt profiles tábla egy szűk, biztonságos vetületét publikálja. Átállítva minden profil-lista a saját kártyánkra zsugorodna. circle\_health\_dashboard — már most is a hostra/adminra szűr, de LATERAL joinokkal aggregál a user\_reports fölött, aminek az RLS-e „saját bejelentés vagy safety reviewer”. Egy körgazda egyik sem, így invoker módban az open\_report\_count és a reports\_30d **\*\*némán nullára esne egy biztonsági dashboardon\*\***. A jelentések alulmérése rosszabb, mint a lint.

Ellenőrizve utólag: a public\_profile\_cards továbbra is 934 sort ad egy sima felhasználónak.

Ez az összefoglaló 2026-09-05-én készült visszamenőleg, a CHANGELOG.md megfelelő bejegyzéséből származtatva, mert ehhez a verzióhoz eredetileg nem készült versioning-artefaktum. A tartalma a changeloból ellenőrizhető; nem a kiadás napján kelt dokumentum.